

1. What are Mobile Vulnerabilities?

Ans: -

i. Mobile vulnerabilities are the weaknesses in smartphones and wireless devices that

attackers exploit to gain unauthorized access to data, applications, or networks.

ii. As mobiles are widely used for banking, e-commerce, emails, and social media, they

carry highly sensitive information.

iii. Attackers exploit insecure Wi-Fi, Bluetooth, or public hotspots to intercept communications.

iv. Malicious apps downloaded from untrusted sources may secretly access contacts,

messages, or financial details.

v. Weak or no authentication (simple PINs, patterns, or no screen lock) makes devices

easy to break into.

vi. Data leakage also occurs when apps request unnecessary permissions like access to

camera, microphone, or location.

vii. Such vulnerabilities can lead to identity theft, financial fraud, unauthorized surveillance, or leakage of confidential organizational data.

viii. Common mobile vulnerabilities include:

a. Insecure Wi-Fi & Bluetooth – attackers can sniff or hijack data.

b. Malicious Apps – fake apps may steal personal or banking details.

c. Weak Authentication – easy PINs or no lock screen.

d. Outdated OS/Apps – unpatched software increases risks.

e. Data Leakage – apps requesting unnecessary permissions.

2. What are different Security Risks for Organizations?

Ans: -

Security risks for organizations are potential threats that can compromise the confidentiality, integrity, and availability of their digital assets, systems, and data. As businesses depend heavily on technology, these risks can lead to financial loss, data theft, or reputational damage if not properly managed.

1. Insider Threats:

Employees or trusted individuals may intentionally or unintentionally leak sensitive data. Insider threats are among the most common organizational risks, often due to negligence or malicious intent.

2. Phishing Attacks:

Cybercriminals send fake emails or links to trick employees into revealing passwords or financial details. Phishing can lead to unauthorized access to organizational systems.

3. Weak or Compromised Credentials:

Using simple passwords or sharing login credentials makes it easy for hackers to infiltrate IT systems. Stolen or reused credentials are a major entry point for attacks.

4. Malware and Ransomware:

Malicious software can infect networks, steal data, or encrypt critical files until a ransom is paid. Ransomware-as-a-Service has made such attacks more frequent and damaging.

5. Third-Party or Business Partner Risks:

Vendors or supply chain partners with weak cybersecurity can expose an organization's systems to attacks, as seen in many large data breaches.

6. Lack of Employee Awareness:

Even the best tools fail if employees are not trained. Uninformed users often fall prey to social engineering or fail to follow security policies.

5 MARKS (CSL)

3. Difference between virus and worm.

Ans: -

Basis of Comparison	Worms	Viruses
Definition	A Worm is a form of malware that replicates itself and can spread to different computers via a Network.	A Virus is a malicious executable code attached to another executable file that can be harmless or can modify or delete data.
Objective	The main objective of worms is to eat the system's resources. It consumes system resources such as memory and bandwidth and makes the system slow in speed to such an extent that it stops responding.	The main objective of viruses is to modify the information.
Host	It doesn't need a host to replicate from one computer to another.	It requires a host is needed for spreading.
Harmful	It is less harmful as compared.	It is more harmful.
Detection and Protection	They can be detected and removed by the Antivirus and firewall.	Antivirus software is used for protection against viruses.
Controlled by	They can be controlled by remote. 	They can't be controlled by remote.
Execution	They are executed via weaknesses in the system.	They are executed via executable files .
Comes from	Worms generally come from the downloaded files or through a network connection.	They generally come from shared or downloaded files.
Symptoms	1. Hampering computer performance by slowing down it 2. Automatic opening and running of programs 3. Sending of emails without your knowledge	1. Pop-up windows linking to malicious websites 2. Hampering computer performance by slowing down it 3. After booting, starting of unknown programs.
Examples	Examples of worms include Morris worm, storm worm, etc.	Examples of viruses include Creeper, Blaster, Slammer, etc.
Interface	It does not need human action to replicate.	It needs human action to replicate.
Speed	Its spreading speed is faster.	Its spreading speed is slower as compared to worms.

5 MARKS

Sr. No.	Feature	Virus	Worms
1.	Types	Stealth virus polymorphic, metamorphic etc.	Email worm, IRC worm, file sharing worm etc.
2.	Mode of spreading	Need host program to spread.	It does not need host it spreads by itself.
3.	What it is?	It is a software program that can copy itself and infect the data or information without the knowledge.	It is self-replicating spreads through a network.
4.	Inception	'Creeper' virus first known virus spread through ARPANET in 1970.	The name originated by the shock wave rider a novel of science fiction in 1975 from where name is adopted.
5.	Prevalence	More than 100, 000 known computer virus have been there through only few have attacked system.	Worm existence is moderate as compare to virus.

4. How cybercrimes differ from most terrestrial crimes?

Ans: -

Basis	Cybercrime	Conventional crime
Methods used to commit the crime	These crimes basically involve the use of computers, the internet, or other digital devices to commit a crime. Examples of cybercrimes include malware attacks, identity theft, and online fraud.	Conventional crime typically involves physical force or the threat of physical force to commit the crime. Examples of conventional crimes include theft, assault, and burglary.
Duration of detection	Remain undetected for a long period as there is no physical presence and no on-ground evidence.	Get detected immediately because it leaves physical traces of the crime.
Types of victims targeted	Cybercrime targets online interconnected systems, digital assets, and sensitive personal information or health information.	Conventional crime tends to target individuals or physical assets such as offices, relatives, and homes.
Scale of crime	Cybercrimes are committed on a large scale because in such a crime physical proximity to the victim is not required. e.g.- A single computer can hack thousands of bank websites. and loot them at a single instance.	on a limited scale as conventional crime comes in physical proximity to the victim. e.g.- A robber can rob one or two banks in a single day only.
Types of Consequences	Victims of cybercrime experience damage to their digital reputation or loss of sensitive personal information that can be used for identity theft.	Conventional crime can have physical, emotional, and financial consequences for victims.
Examples	Spamming, Phishing , Hacking, Cyberbullying, Cyberstalking, Malware, and many more.	Murder, Extortion, Bullying, and many more.

5. Explain the objectives of IT Act 2000.

Ans: -

- i. Indian government and different security agencies think that taking right decision at right time is very important for solving the cyber-crime and related issues or cases.
- ii. The Government of India passed the Information Technology Act 2000 (Act No.21 of 2000) along with legal notice on October 17, 2000.
- iii. The Information Technology Act, 2000, is the first historical step taken by the Government of India towards promoting the growth of the E-commerce, e-transactions and facilitates e-governance and prevents computer-based crimes. iii. In Information Technology Act, 2000 two more sections are added section 69, 69 A and 69 B to strengthen the IT Act 2000.
- iv. Section 69 is the provision made to handle the issues like interception, monitoring or decryption of information of any computer resource.
- v. Section 69A and 69 B is the provision made to handle the issues like blocking public web sites, monitoring and collecting network traffic from any computer resources. Later on scope enhanced by adding IT Act 2006 into it.
- vi. Cyber-crime doesn't stop here because of rapid increase in the use of internet cyber-crime is also increasing even with fast rate which includes new things like child pornography, publishing sexually explicit content in electronic form and porn videos. vii. To avoid all these crimes the Indian Government with prior permission from Presidents of India in February 2009 I.T.
- viii. Amendment Act 2008 was passed along with legal notice elective from 27.10 2008. This law brought large number of cyber-crimes under scrutiny.
- ix. Some of the important features of this IT Act laws are provide protection to cover electronic data interchange, e- transactions, e-governance, e-commerce, protection of personal data and implementing proactive measures to reduce the risks of computer security.
- x. Till date thousands of cyber-criminal cases are registered under Indian IT Act 2000 and IT Act 2008 to control the cyber-crimes.

6. What is Cybercrime? Who are Cybercriminals? Explain.

Ans: -

A. Cybercrime

- i. Cybercrime refers to the unlawful acts that involve the use of computers, networks, or the internet to commit offenses such as data theft, fraud, or damage to systems.
- ii. These crimes can target individuals, organizations, or even governments, often with the intention to harm someone's reputation, steal confidential data, or cause financial loss.
- iii. Cybercrimes may cause direct harm (like stealing money or information) or indirect harm (like emotional distress or system disruption). The biggest threat today lies in the financial and data security of individuals and nations.
- iv. Types of Cybercrime:
 - a. Hacking – Unauthorized access to computer systems or networks.
 - b. Unwarranted mass-surveillance – Illegally monitoring users' online activity.
 - c. Child pornography & Child grooming – Exploiting minors through the internet.
 - d. Copyright infringement – Copying or distributing digital content without permission.
 - e. Money laundering & Cyber extortion – Using the internet for illegal financial activities.
 - f. Cyber terrorism – Attacking systems to spread fear or threaten national security.

B. Cybercriminals

Who are Cybercriminals?

- i. Cybercriminals are individuals or groups who intentionally misuse technology to commit cybercrimes.
- ii. They include:
 - Hackers / Crackers: Break into systems for data theft or personal gain.
 - Fraudsters: Use phishing or online scams to steal money or identity.
 - Cyber Terrorists: Attack critical systems to spread fear or disrupt national operations.

5 MARKS (CSL)

- Insiders: Employees or trusted persons who misuse organizational information.

7. How Cybercrimes differs from most terrestrial crimes?

Ans: -

FOR ANSWER REFER 5 MARKS QUESTION NO.4

8. What are different Security Risks for Organizations?

Ans: -

FOR ANSWER REFER 5 MARKS QUESTION NO.2

9. Outline the challenges for securing data in business perspective.

Ans: -

In today's digital age, data is the most valuable asset for any organization. Securing this data from theft, misuse, or unauthorized access is one of the biggest challenges businesses face. The complexity of networks, employee mobility, and increasing cyber threats make data protection a difficult task.

1. Data Breaches and Cyber Attacks

Organizations face continuous threats from hackers who try to steal confidential business, customer, or financial data. Data breaches can severely affect reputation, customer trust, and revenue.

2. Insider Threats

Employees, contractors, or partners with legitimate access may intentionally or accidentally leak sensitive data. This is difficult to detect and prevent.

3. Weak Access Controls

Inadequate authentication methods or poor password practices make it easier for attackers to gain unauthorized access to company databases or networks.

4. Third-Party and Cloud Risks

Businesses often rely on third-party vendors and cloud services. Any security weakness in these external systems can compromise company data.

5. Lack of Employee Awareness

Even with advanced security systems, employees who are unaware of security protocols (like phishing or unsafe Wi-Fi) can unintentionally expose data to threats.

6. Regulatory and Compliance Challenges

Businesses must comply with multiple data protection laws (like IT Act, GDPR, etc.). Failing to meet these standards can lead to legal and financial penalties.

7. Increasing Use of Mobile Devices and Remote Work

With employees accessing data from mobile phones and remote networks, it becomes harder to ensure that data remains secure outside the company's physical boundaries.

10. Write a short note on:

a. Cyberstalking and harassment.

Ans: -

- i. Cyberstalking is an activity in which a person or abuser or stalker stalks or harass another person or victim by misusing the internet or electronic media.
- ii. In cyberstalking a stalker may contact a person either by an email, social media, messaging apps or other online media.
- iii. To harass a person a stalker may post messages, pictures or information online about a person. Some may also track location or online activities.
- iv. Cyberstalkers may not track victims physically, but they do so digitally.
- v. The cyberstalkers do adopt all types of technological and digital instruments assault but it is an emotional assault and harassment which is carried out by using electronic media. However, the provisions provided to it are different than real-life situations.
- vi. For example, if you've received a few negative comments on Facebook and Instagram, it may upset or annoy you, but this isn't cyberstalking yet.
- vii. For some people, such as semi celebrities looking for attention, negative comments are actually welcomed.

viii. Following are the kinds of cyberstalking that till now has been reported worldwide: -

- a. Catfishing: In Catfishing, Stalkers create a fake profile on social media to approach victims. Sometimes they copy the existing user's profile with photos to look it like a real one.
- b. Monitoring location check-ins on social media: Stalkers keep an eye on the activities of a victim from their check-ins on social media such as Facebook and Instagram. This is an easier job for a stalker to gauge a victim's behavioural pattern quite accurately.
- c. Hijacking webcam: Computers webcam hijacking is one of the most disgusting methods of cyberstalking to invade the victim's privacy. Stalkers push malware infected files into the victim's computer which gives them access to the webcam.
- d. Installing Stalkerware: - One more method which is increasing its popularity is the use of Stalkerware. It is a kind of software or spyware which keeps the track of the location, enable access to text and browsing history, make an audio recording, etc. And an important thing is that it runs in the background without any knowledge to the victim.

How to avoid Cyberstalking?

a. Keep a Low Profile: -

- Keeping a subdued online existence is tough for some people, especially those who need to use online platforms for self-promotion or business-related activities.

b. Update your software: -

- Keeping your software up to date may not be the first thing that springs to mind when you think about cyberstalking prevention. However, regular software updates are crucial when it comes to preventing information leaks. Many updates are developed to patch security vulnerabilities and help ensure your information remains safe.

c. Hide your IP address: -

- Many applications and services reveal your IP address to the person with whom you're communicating. This may seem unimportant, but this information is directly related to your personal data. To mask your IP address, you can use a Virtual Private Network (VPN). This hides your real IP address and replaces it with from a location of your choice, so you could

even appear to be in a different country, it also encrypts all of your internet traffic, keeping it safe from the prying eyes of hackers.

d. Avoid disclosing sensitive information: -

- Surprisingly, many people constantly share personal information about themselves, even outside of social media platforms. By filling out questionnaires or submitting applications for coupons, you are increasing the likelihood of someone getting their hand on your personal data and possibly making cyberstalking more accessible.

e. Maintain good digital hygiene: -

- ‘Digital hygiene’ is a new term but represents a very important topic, especially with pe social networks. Maintaining good digital hygiene helps protect you from cyber harassment, cyberbullying and cyberstalking.

b. Botnets: -

Ans: -

i. A Botnet is considered one of the biggest modern threats to cybersecurity because cybercriminals can secretly take control of almost any internet-connected device — from personal computers and laptops to mobile devices, servers, and even IoT gadgets like DVRs.

ii. The term botnet comes from “robot + network”, meaning a network of machines that work automatically under the control of an attacker rather than the real owner.

iii. When a device gets infected by malicious code, it becomes a bot or zombie, and when many such compromised devices come together, they form a zombie army under the control of a cybercriminal (botmaster).

iv. Users usually have no idea that their system is infected because botnet malware runs silently in the background.

v. Once under the attacker’s control, botnets are used for malicious activities such as sending spam emails, click-fraud campaigns, stealing sensitive data, generating malicious web traffic, and launching Distributed Denial-of-Service (DDoS) attacks.

vi. The malware behind a botnet searches the internet for vulnerable devices and infects as many as possible.

vii. Even if one infected device contributes only a small amount of bandwidth or processing power, a botnet with millions of bots working together can generate an enormous amount of malicious traffic — while still remaining undetected by the user.

viii. Botnet operations mainly follow two structures:

- a. Client–Server Model – A centralized Command-and-Control (C&C) server sends commands to bots, which remain dormant until instructions are received.
- b. Peer-to-Peer Model (P2P) – A decentralized approach where infected devices communicate with each other, making botnets harder to trace and shut down.

ix. Botnet Prevention:

Botnet infection can be reduced by:

- Keeping the operating system updated regularly
- Avoiding email attachments from unknown or suspicious sources
- Avoiding downloads from P2P and file-sharing websites
- Not clicking unknown or suspicious links
- Installing trusted antivirus software

c. Mobile/ Cell Phone attacks: -

Ans: -

Q. Write a short note on Attacks on Mobile/Cell Phones.

A smartphone user is exposed to various threats when they use their phone. In just the last few years, the number of unique mobile threats grew much more. These threats can disrupt the operation of the smartphone, and transmit or modify user data. For these reasons, the applications deployed there must guarantee privacy and integrity of the information they handle.

There are three prime targets for attackers :

- **Data :** smartphones are devices for data management, therefore they may contain sensitive data like credit card numbers, authentication information, private information, activity logs (calendar, call logs);
- **Identity :** smartphones are highly customizable, so the device or its contents are associated with a specific person. For example, an attacker may want to steal the identity of the owner of a smartphone to commit other offenses;
- **Availability :** by attacking a smartphone one can limit access to it and deprive the owner of the service.

© A SACHIN SHAH Venture

Followings are some of the most common types of Wireless and Mobile Device Attacks :

- (i) **Mishing** : Mishing is a combination of mobile phone and phishing. Mishing is similar to phishing the only difference is technology. The attack is chances increases when you purchase goods using the M-commerce, someone can cheat a m-commerce customer by making a call using some malicious number so by the end of the call your mobile is infected with the malwares.
- (ii) **Vishing** : Voice call phishing is known as vishing. For instance, the cybercriminal may employ war dialers to place a call and play a recorded message informing the victim that their credit card may be blocked and that in order to keep it active, they must supply the card data. The user may become a victim of a phishing attempt if he provides the card data. However the cybercriminal uses many other ways to perform phishing like voice mail.
- (1) **SMiShing** : Smishing become common now as smartphones are widely used. SMiShing uses Short Message Service (SMS) to send fraud text messages or links. The criminals cheat the user by calling. Victims may provide sensitive information such as credit card information, account information, etc. Accessing a website might result in the user unknowingly downloading malware that infects the device.
- (2) **War driving** : War driving is a way used by attackers to find access points wherever they can be. With the availability of free Wi-Fi connection, they can drive around and obtain a very huge amount of information over a very short period of time.
- (3) **WEP attack** : Wired Equivalent Privacy (WEP) is a security protocol that attempted to provide a wireless local area network with the same level of security as a wired LAN. Since physical security steps help to protect a wired LAN, WEP attempts to provide similar protection for data transmitted over WLAN with encryption. WEP uses a key for encryption. There is no provision for key management with Wired Equivalent Privacy, so the number of people sharing the key will continually grow. Since everyone is using the same key, the criminal has access to a large amount of traffic for analytic attacks.
- (4) **WPA attack** : Wi-Fi Protected Access (WPA) and then WPA2 came out as improved protocols to replace WEP. WPA2 does not have the same encryption problems because an attacker cannot recover the key by noticing traffic. WPA2 is susceptible to attack because cyber criminals can analyze the packets going between the access point and an authorized user.

(MU-New Syllabus w.e.f academic year 22-23/M7-163)

- (5) **Bluejacking** : Bluejacking is used for sending unauthorized messages to another Bluetooth device. Bluetooth is a high-speed but very short-range wireless technology for exchanging data between desktop and mobile computers and other devices.
- (6) **Replay attacks** : In Replay attack an attacker spies on information being sent between a sender and a receiver. Once the attacker has spied on the information, he or she can intercept it and retransmit it again thus leading to some delay in data transmission. It is also known as playback attack.
- (7) **Bluesnarfing** : It occurs when the attacker copies the victim's information from his device. An attacker can access information such as the user's calendar, contact list, e-mail and text messages without leaving any evidence of the attack.
- (8) **RF Jamming** : Wireless signals are susceptible to electromagnetic interference and radio-frequency interference. Radio frequency (RF) jamming distorts the transmission of a satellite station so that the signal does not reach the receiving station.

OR

i. Smartphones have become an essential part of daily life, but their increased usage has made users more exposed to cyber threats.

ii. In recent years, the number of mobile-specific attacks has grown rapidly, and these attacks can disrupt phone operations, steal personal information, or even modify stored data.

iii. Therefore, applications and systems on smartphones must ensure privacy and integrity of user data.

iv. Attackers mainly target three things on a smartphone:

- a. **Data** – Smartphones store sensitive information like credit/debit card details, authentication credentials, private files, call logs, calendars, etc. Attackers steal this data for financial gain or misuse.
- b. **Identity** – Smartphones are linked to individual users, so attackers attempt to steal the identity of the owner for committing fraud or other crimes.
- c. **Availability** – By attacking a smartphone, cybercriminals can restrict or block access to services, depriving the user of device functionality.

v. Common Mobile & Wireless Device Attacks: -

Some of the well-known forms of wireless and mobile attacks include:

- Mishing – A combination of mobile and phishing where users are tricked through malicious phone calls related to online shopping or payments.
- Vishing – Voice call phishing where attackers play fraudulent recorded messages to steal credit card data.

vi. Additional common smartphone attacks include:

- a. SMiShing – Uses SMS to send malicious messages or links to extract confidential information like bank details or login data.
- b. War Driving – Attackers locate insecure Wi-Fi access points by driving around and abuse the network to steal information.
- c. WEP Attack – Exploits the weaknesses of WEP encryption, giving attackers access to traffic for analytical attacks.
- d. WPA Attack – Even though WPA improved over WEP, WPA2 is still susceptible because attackers can analyze packets to recover the key and attack connected users.

More wireless cyberattacks include:

- e. Bluejacking – Sending unauthorized messages to nearby Bluetooth devices.
- f. Replay Attack – Intercepting and retransmitting data between a sender and receiver to cause delays or unauthorized actions.
- g. Bluesnarfing – Stealing personal data stored in the phone via Bluetooth, such as contacts, emails and messages.
- h. RF Jamming – Disturbing wireless communication through electromagnetic interference to block signals.

d. DOS attack: -

Ans: -

- i. A Denial of Service (DoS) attack is a cyberattack in which the attacker tries to make a system, network, or online service unavailable to legitimate users.
- ii. Instead of hacking or stealing information, the attacker's main goal is to block access by overloading the target with unnecessary traffic or repeated requests so that genuine users are unable to connect.

5 MARKS (CSL)

iii. In this attack, the attacker keeps sending large numbers of requests, emails, spam packets, or traffic, which consumes the victim's bandwidth and network resources.

iv. As a result, the system becomes extremely slow, crashes, or stops responding completely.

v. It is a continuous effort to make the victim unable to use any internet service or resource.

vi. Websites or services related to financial transactions—such as bank websites and credit card payment gateways—are common targets because disruption here affects both the organisation and its customers.

vii. Also, networks like mobile phone networks and credit card gateway networks are highly vulnerable to DoS attacks.

viii. How a DoS Attack Works: -

A DoS attack typically:

- a. Floods the network with unnecessary traffic
- b. Damages connection between two systems
- c. Disrupts services to authorized users
- d. Prevents individuals from accessing network-based services

Attackers often use techniques like buffer overflow, where the packet is broken into small chunks and repeatedly sent to the victim device or network using fake IP addresses to consume bandwidth and processing capacity.

ix. Classification of DoS Attacks: -

DoS attacks are classified as:

- a. Bandwidth Attack – Consumes the allocated bandwidth of a website or service by repeatedly loading webpages or sending huge volumes of traffic until genuine users are blocked.
- b. Logic Attack – Exploits software weaknesses or loopholes (e.g., in TCP/IP stack) to make the system vulnerable and crash.
- c. Protocol Attack – Consumes large amounts of resources in the victim's system by abusing protocol-specific features.
- d. Unintentional DoS Attack – Occurs when a service becomes unreachable due to sudden popularity and high traffic, even without malicious intent.

x. Common Examples of DoS Attacks: -

Examples of DoS attacks mentioned in your material:

- Flood Attack – Overloads the victim's system with “n” number of ping packets causing traffic that the system cannot handle.
- Ping of Death – Sends oversized ICMP packets, forcing the victim's system to crash or freeze.
- SYN Attack – Sends SYN connection requests but never completes handshaking (SYN-ACK-ACK), filling up server buffer space and blocking new connections.

e. DDOS attack: -

Ans: -

i. A Distributed Denial of Service (DDoS) attack is a cyber-attack in which multiple compromised computers (called zombie systems or botnets) are used to target a single system such as a website, server, or network resource.

ii. The main objective of a DDoS attack is to flood the target with excessive traffic, messages, requests, or malformed packets so that the system becomes slow, crashes, or becomes completely unavailable to legitimate users.

iii. During a DDoS attack, the attacker controls a group of infected systems using a control master program, as shown in the figure in the notes.

iv. The attacker sends a command, and all the connected daemon machines start sending traffic to the victim at the same time.

v. This "many-to-one" attack pattern makes DDoS more powerful and harder to detect or prevent compared to a normal DoS attack.

vi. Characteristics of DDoS Attacks: -

- Attempts to flood network bandwidth, preventing normal traffic.
- Disrupts communication between legitimate systems.
- Prevents a particular user, organization, or service from accessing network resources.

vii. Common Techniques Used in DDoS: -

Some widely known DDoS attack methods include:

5 MARKS (CSL)

- Smurf Attack → Uses ICMP echo traffic to broadcast packets, multiplying replies.
- SYN Flood Attack → Exploits the TCP three-way handshake by sending multiple SYN requests without completing the connection.
- UDP Flood Attack → Sends forged UDP packets to overwhelm network ports and consume bandwidth.

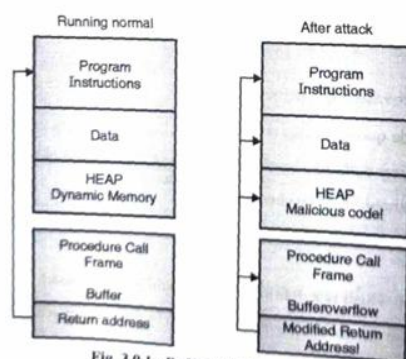
viii. Measures to Protect Against DDoS: -

- Implementing filters on routers
- Disabling unused network services
- Applying security patches
- Using fault-tolerant network configuration
- Performing network intrusion detection
- Using specialized tools like DDOS finders, Zombie Zapper, or remote intrusion detectors.

f. Buffer Overflow attack: -

Ans: -

- GQ.** What is buffer overflow in software security?
- While programming, a programmer can make mistakes/errors. Most of these errors are not intentionally done. Many such kind of errors do not have huge impact on security. Program may produce wrong or incorrect results but it is non-malicious.
 - Following are the three types of non-malicious program errors,
 - (i) Buffer overflows
 - (ii) Incomplete mediation
 - (iii) Time-of-check to time-of-use errors (TOCTOU)
 - Attacker can insert malicious data values / instruction codes into overflow space.
 - Array bound checking is not performed by C compiler, pointer limits cannot be defined as well.
 - **Example :** `int B[15];`
 - Here the array bound is (0 to 14). i.e. `B[0].....B[14]`.
 - If anything inserted after that bound then the adjacent data is overwritten.
 - Attacker can overwrite users data, changes users instruction, overwrite OS data, changes OS instructions. Thus, can get complete control of a program or OS. This is also known as aliasing.



- As shown in Fig. 3.9.1 attacker changes the return address and thus can transfer the control of the program.

Types of buffer overflow attacks

- (i) **Stack-based buffer overflows** are common, and leverage stack memory that only exists during the execution time of a function.
- (ii) **Heap-based attacks** are harder to carry out and involve flooding the memory space allocated for a program beyond memory used for current runtime operations.

OR

- i. A Buffer Overflow attack is a security attack that takes advantage of programming mistakes where a program writes more data into a buffer (temporary storage area) than it can hold.
- ii. While programming, developers may unintentionally make errors — most of them are non-malicious — but they can still become a serious security weakness.
- iii. In the C language, no array bound checking is performed, and pointer limits are not defined, so if data is inserted beyond the allocated memory space, the adjacent memory gets overwritten.
- iv. For example, if an array `int B[15]` is created, valid memory locations are `B[0]...B[14]`. Anything written beyond this range overwrites other important parts of the memory.
- v. An attacker can exploit this mistake by inserting malicious values or instruction codes into the overflow space, which allows modifying return addresses, user data, OS data, or program instructions.
- vi. Once the return address is changed, the attacker can hijack the execution flow and gain control of the program or even the operating system.
- vii. This technique is also called aliasing.
- viii. How a Buffer Overflow Attack Works: -
 - In normal execution, memory contains program instructions, data, heap (dynamic memory), procedure call frame, buffer and return address.
 - After an overflow attack, extra malicious data spills into the buffer and overwrites the return address. When the program ends the function call, the system jumps to the modified (malicious) return address, giving the attacker control instead of returning to legitimate instructions.
- ix. Types of Buffer Overflow Attacks: -
 - a. Stack-based buffer overflow – Most common; exploits the stack memory used during execution of a function.
 - b. Heap-based attack – More difficult; involves flooding memory space allocated for runtime operations beyond its intended use.

g. Salami Attack: -

Ans: -

A **Salami attack**, also known as **salami slicing**, is a computer-based financial fraud in which an attacker steals **very small amounts of money or data repeatedly**. Each individual deduction is too tiny to attract attention (like slicing very thin pieces of salami), but over time all the small thefts accumulate into a **large, significant loss**. This attack typically exploits automated financial systems where rounding, interest calculation, or fee adjustments occur regularly.

How the Attack Works

In a typical salami attack, the attacker modifies a software script, financial module, or accounting logic. Whenever a transaction takes place, the program makes a tiny adjustment — such as **rounding down fractions of a cent** — and secretly **diverts the leftover amount** into an account controlled by the attacker. Since each user loses an extremely small amount, discrepancies often go unnoticed by customers as well as auditors. Over thousands or millions of transactions, the attacker collects a substantial sum without raising major alarms. The attack is largely **automated**, making it easy to run over a long period.

Common Targets and Attack Vectors

Salami attacks commonly target:

- **Banking systems**, especially interest computation, payroll deposits, or fee rounding.
- **Billing and utility systems**, where large customer volumes and automated billing make tiny deductions hard to detect.
- **E-commerce platforms and payment processors**, which perform numerous micro-transactions daily.
- **Legacy or poorly monitored systems** with weak audit trails or insufficient code reviews.

These environments are attractive because small values are frequently adjusted or rounded, providing opportunities to hide fraudulent deductions.

Why Attackers Prefer Salami Attacks

The main advantage is **low detection risk**. Tiny deviations rarely trigger alerts or user complaints. Once the malicious code is inserted, the attack can run automatically with minimal human involvement. Over time, these micro-thefts

accumulate into considerable financial gains, making it a profitable long-term scheme for insiders or sophisticated attackers.

Impact and Consequences

Salami attacks can cause **gradual but major financial losses** to banks, customers, or organizations. When discovered, they damage customer trust, trigger regulatory investigations, and may require extensive audits and system repairs. Institutions may also face heavy fines if poor internal controls enabled such fraud.

Detection & Prevention

Organizations can detect salami attacks using statistical monitoring of rounding patterns, automated reconciliation of transaction totals, strict logging, and anomaly detection tools. Prevention requires strong internal controls such as **code reviews**, segregation of duties, cryptographic log protection, and continuous monitoring for unusual small-value transfers. Since many salami attacks are insider-led, employee screening and monitoring are also essential.

H. Trojan Horse and Backdoor

Ans: -

Trojan Horse: -

A Trojan Horse is a type of malicious software that disguises itself as a legitimate or useful program in order to trick users into installing it. The name comes from the Greek myth, where soldiers hid inside a wooden horse to secretly enter Troy. Similarly, a Trojan hides harmful code inside something that looks harmless.

Once installed, a Trojan does not replicate like a virus, but it performs unauthorized activities such as stealing data, spying on the user, or allowing external attackers to control the system. Trojans often spread through email attachments, fake software downloads, cracked applications, or malicious websites.

Common functions of Trojans include:

- Keylogging and stealing passwords or banking details
- Deleting or modifying files
- Installing additional malware (worms, ransomware)
- Granting remote access to attackers

- Monitoring user activity or capturing screenshots

Because Trojans rely on social engineering, users unknowingly help in installing them. Good antivirus tools, safe browsing habits, and avoiding unknown downloads are key preventive measures.

Backdoor: -

A Backdoor is a hidden entry point in a system or software that bypasses normal authentication. It allows attackers (or sometimes developers) to gain unauthorized remote access to a computer without the user's knowledge. Backdoors may be intentionally added by attackers through malware, or unintentionally left behind due to poor coding practices.

Once a backdoor is active, an attacker can:

- Access the system anytime without logging in
- Steal or modify sensitive data
- Install or remove programs
- Take full control of the system
- Use the compromised system to launch further attacks

Backdoors are extremely dangerous because they allow continuous, covert access and are difficult to detect. They often accompany Trojans — meaning a Trojan may install a backdoor to give long-term access to the attacker.

Prevention techniques include:

- Regular system and security patching
- Strong authentication and monitoring of unusual network activity
- Removal of unused services and ports
- Use of intrusion detection systems and strict access control

I. Steganography

Ans: -

Steganography is a technique used to hide a message, file, or image within another message, image, audio, or video so that no one is aware that communication is taking place. The word Steganography is derived from a Greek term meaning “covered writing” or “secret writing”.

The main goal of steganography is to ensure secrecy by embedding sensitive data into a normal-looking cover medium like an image, document, or audio file. Even if someone sees the file, they should not be able to detect that hidden information exists inside it.

Another important concept related to steganography is Steganalysis, which is similar to cryptanalysis. The purpose of steganalysis is to detect whether a message contains hidden information and, if possible, extract it.

Advantages of Steganography

- It provides an additional layer of security by hiding the existence of the message.
- Can be used along with cryptography for stronger protection.
- Useful for secure communication over insecure channels like the internet.

Disadvantages / Limitations

- If the steganographic method is weak, the hidden message can be detected by steganalysis.
- Even a small change in the file format (e.g., compression or resizing) may destroy the hidden message.
- Attacks on Steganography (Any 2 for exam writing)

Some common attacks are:

1. **Stego-only attack** – Only the file containing hidden data is available for analysis.
2. **Known-carrier attack** – The analyst has both the original file and the file with the hidden message for comparison.
3. **Reformat attack** – Changing the file format destroys the hidden data.

J. HIPAA

Ans: -

The **Health Insurance Portability and Accountability Act (HIPAA)** was enacted in 1996 by the U.S. Congress as a federal law to safeguard the privacy, security, and integrity of individuals' medical information. It establishes national standards for the lawful use, storage, and disclosure of **Protected Health Information (PHI)**. HIPAA is regulated by the Department of **Health and Human Services (HHS)** and enforced by the **Office for Civil Rights (OCR)**.

Objectives of HIPAA

- The primary aim of HIPAA is to ensure the confidentiality and security of patient health data. Its objectives include:
- Protecting PHI from unauthorized access or misuse.
- Ensuring confidentiality, integrity, and availability of health records.
- Standardizing electronic health transactions across healthcare systems.
- Preventing fraud, abuse, and improving accountability among healthcare providers.
- Promoting a secure and efficient environment for sharing health information.

Role of the Office for Civil Rights (OCR)

The OCR is responsible for overseeing and enforcing HIPAA compliance. It conducts audits and investigates violations, issues guidance regarding data protection practices, and imposes civil or criminal penalties when organizations fail to comply. HIPAA compliance is considered a continuous process, requiring organizations to regularly update and maintain their privacy and security safeguards.

Protected Health Information (PHI)

PHI refers to any personal, demographic, or medical information that can identify an individual and relates to their health condition or medical services received. Examples include names, addresses, phone numbers, Social Security numbers, medical records, diagnoses, insurance details, and biometric identifiers. Any identifiable data used in a healthcare context is classified as PHI under HIPAA.

Who Must Comply with HIPAA?

HIPAA applies to two key groups:

- Covered Entities – These handle PHI directly.
Examples: hospitals, clinics, doctors, nurses, health insurance companies, laboratories, and healthcare clearinghouses.
- Business Associates – These are third-party vendors that process or access PHI on behalf of covered entities.
Examples: billing firms, cloud storage providers, IT support companies, transcription services, legal or accounting firms dealing with health records.

Both groups must follow HIPAA standards and ensure PHI protection.

Major HIPAA Rules:

HIPAA consists of several core regulatory rules:

- Privacy Rule – Defines how PHI can be used or shared and grants patients rights over their health information.
- Security Rule – Focuses on protecting electronic PHI (ePHI) through administrative, technical, and physical safeguards.
- Breach Notification Rule – Requires mandatory reporting of data breaches to affected individuals and HHS; large breaches (500+ individuals) must be publicly reported.
- Omnibus Rule – Expands compliance requirements to business associates and strengthens data protection responsibilities through Business Associate Agreements (BAAs).

K. Classification of Cyber Crime

Ans: -

Cybercrime can be grouped into different categories based on who or what the target is. This classification helps understand the intention behind the crime and the type of harm caused. The major classifications are shown in your diagram and explained in detail below.

1. Cybercrime Against Individuals

These crimes directly target a single person or a small group. The goal is often to steal personal data, invade privacy or cause emotional or financial harm.

Examples

- Hacking personal accounts (email, social media, banking)
- Cyberstalking and online harassment
- Identity theft using stolen documents or passwords
- Phishing attacks to trick users into revealing information
- Morphing or misuse of personal photos

Impact

Victims may face financial loss, mental stress, reputational damage and loss of privacy.

2. Cybercrime Against Property

Here, criminals target digital assets, intellectual property or online financial resources. The aim is usually financial gain or to disrupt services.

Examples

- Unauthorized access to computer systems
- Data theft or destruction of files
- Online credit card fraud
- Spreading viruses or ransomware
- Software piracy and copyright violation

Impact

Businesses and individuals may lose money, data or control of their systems.

3. Cybercrime Against Organizations

Large businesses, institutions and corporations are targeted to damage operations, steal sensitive corporate data or disrupt services.

Examples

- Network intrusions into company servers
- Stealing confidential documents, trade secrets or customer data
- Distributed Denial of Service (DDoS) attacks to shut down websites
- Ransomware attacks demanding payment to restore access
- Website defacement of company portals

Impact

Organizations face service outages, financial losses, damaged customer trust and legal consequences.

4. Cybercrime Against Society

These crimes affect large groups of people or the functioning of the society. They aim to disturb public order, spread fear or manipulate public opinion.

Examples

- Online hate speech and misinformation
- Cyber terrorism targeting essential services
- Spreading fake news to create social unrest
- Online lottery scams and fraud schemes
- Drug trafficking or illegal sale of weapons through the dark web

Impact

Cybercrimes at this level can disrupt national security, damage social harmony and manipulate communities.

5. Crimes Emanating from UseNet/Newsgroups

This includes crimes committed through online discussion forums, newsgroups and community platforms. These spaces allow criminals to share illegal content or plan coordinated acts.

Examples

5 MARKS (CSL)

- Sharing child pornography or abusive content
- Illegal trading of hacked data or malicious software
- Organizing hate groups or extremist activities
- Posting pirated movies, software or copyrighted material

Impact

These platforms allow criminals to collaborate easily and spread harmful content to a wide audience.

L. Cyber Security

Ans: -

Cyber security refers to the set of practices, technologies and processes designed to protect computer systems, networks, devices, and digital data from unauthorized access, misuse, attacks or damage. In simple words, it is all about keeping our digital world safe from cyber threats like hacking, malware, data theft and online fraud. As our personal life, business and government services increasingly depend on the internet, cyber security has become essential for ensuring privacy, trust and smooth functioning.

Explanation of Cyber Security

1. Protecting Data and Privacy

One of the core goals of cyber security is to protect sensitive information. This includes personal details, banking information, business documents and confidential records. Cyber security ensures that only authorized people can access this data and prevents misuse or theft.

2. Securing Computer Systems and Networks

Cyber security focuses on safeguarding hardware, software and network infrastructure. Firewalls, antivirus tools, encryption and secure configurations protect systems from malware, viruses and unauthorized intrusions. These tools act like digital shields that block suspicious activity.

3. Preventing Cyber Attacks

Cyber attacks like phishing, ransomware, DDoS attacks or identity theft are common today. Cyber security helps identify threats early, block them and reduce

the damage. Modern systems use threat detection tools, monitoring systems and automated alerts to respond quickly.

4. Ensuring Reliability of Services

Banks, hospitals, educational institutions and government departments depend on stable computer systems. Cyber security ensures that these services run smoothly without disruptions caused by attackers or system failures. This reliability is crucial for public trust.

5. Creating Awareness and Safe Practices

Technology alone cannot solve everything. Cyber security also includes educating users about safe online habits like using strong passwords, avoiding unknown links, enabling two-factor authentication and being alert to scams. Human awareness is often the strongest defense.

6. Supporting National Security

Cyber security is not limited to individuals and companies. The country's critical infrastructure—like power grids, transportation systems, defense networks and communication channels—needs strong protection. Cyber warfare and digital espionage are real threats, so nations invest heavily in cyber defense.

7. Combating Evolving Threats

Cyber threats keep evolving. Attackers use new techniques like social engineering, AI-enabled attacks and advanced malware. Cyber security must constantly update tools, strategies and policies to stay ahead. This makes it a dynamic field that always adapts to new risks.

M. Cyber Defamation

Ans: -

- i. Cyber Defamation is defaming someone by harming their public image and reputation in the digital space.
- ii. It typically involves the bully(ies) posting or commenting persistent destructive criticism of the victim online, on publicly accessible platforms such as social media, to create a negative, false perception of the victim in front of their contacts.

iii. When such acts are committed using the internet, social media, emails, or websites, it is called Cyber Defamation. It is also known as online defamation or cyber libel.

iv. Cyber defamation can be defined as “the publication of defamatory material against a person with the help of computers or the internet to harm their reputation.”

v. Types of Cyberdefamation: -

- a. Publishing false content on websites/blogs – e.g., writing negative fake reviews to damage a business.
- b. Email defamation – sending defamatory emails to harm an individual’s or company’s image.
- c. Social media defamation – spreading fake news, memes, or posts targeting a person on platforms like Facebook, Twitter, Instagram.
- d. Fake profiles – creating a false identity and posting objectionable content in someone’s name.

vi. Indian Legal Provisions for Cyber Defamation: -

- a. Section 499 & 500 of IPC – deals with defamation (punishment up to 2 years imprisonment and fine).
- b. Section 66A of IT Act (now struck down in 2015) – earlier covered offensive messages sent online.
- c. Victims can file a complaint in Cyber Crime Cells or take civil action for damages.

vii. Impact of Cyber Defamation: -

- a. Harms personal dignity and mental health of individuals.
- b. Damages goodwill of companies and brands.
- c. Creates mistrust and misuse of freedom of expression on the internet.

N.SOX

Ans: -

The Sarbanes–Oxley Act of 2002, commonly known as SOX, was introduced in the United States to ensure accountability, transparency, and accuracy in corporate financial reporting. The act was passed mainly to prevent financial fraud and ensure that senior management takes responsibility for internal controls and the reliability of financial statements.

SOX includes both criminal and civil penalties for violations. As per the act:

- Section 302 requires the CEO and CFO to certify that financial reports are accurate and that appropriate internal controls exist over financial reporting.
- Section 404 mandates documenting and validating internal controls, and requires external auditors to certify their effectiveness.
- Section 409 demands real-time disclosure of significant financial changes that may affect investors.
- Section 802 requires organizations and auditors to retain financial documents and records for at least seven years.

SOX focuses on the accuracy of financial statements and controls related to income, expenses, auditing, and reporting. It also emphasizes network and information security, since safeguarding financial data is essential for compliance. The Public Company Accounting Oversight Board (PCAOB) was created as part of SOX to define and enforce auditing standards.

Who is Affected by SOX?

Any company publicly traded in the United States must comply with SOX. This also includes subsidiaries and some non-US multinational companies operating in the US. Private companies may voluntarily comply if preparing for IPOs or funding.

Key IT Requirements Under SOX

- Organizations must maintain a written security policy.
- They must monitor, audit, and secure access to financial data.
- Continuous monitoring tools like SIEM systems and intrusion detection mechanisms are commonly used.

- Companies must show incremental progress toward full compliance and maintain reliable, traceable electronic records.

O. GLBA (Gramm–Leach–Bliley Act)

Ans: -

The Gramm–Leach–Bliley Act (GLBA) was passed in 1999 after the merger of Citicorp and the Travelers Group. The main purpose of GLBA is to ensure that financial institutions protect the confidentiality, integrity, and privacy of customer information. Under this act, protecting customer data is no longer just a good practice — it is now a legal requirement.

GLBA helps break the legal barriers between financial sectors like insurance, banking, and brokerage services, allowing them to merge and share information. However, GLBA also ensures that customers have control over how their Personal Information (PI) is shared, which may include sensitive data such as financial details and even health-related information.

GLBA Standards and Requirements:

GLBA applies to many financial sectors including banks, ATM operators, insurance companies, tax preparers, appraisers, and financial advisors. The act makes activities like pretexting (identity-based fraud) illegal.

Key safeguards under GLBA include:

- 16 CFR Part 314 (Safeguarding Customer Information Rule)
- Financial Privacy Rule
- Compliance oversight by bodies like the Federal Reserve, FTC, and the Federal Deposit Insurance Corporation (FDIC).

GLBA – Key IT Requirements:

To comply with GLBA, organizations must:

- Have a written security policy.
- Perform risk assessment and maintain security baselines.
- Monitor and report access to files or databases containing consumer information.
- Notify customers if their data is compromised.

5 MARKS (CSL)

- Train employees through awareness programs.
- Detect, prevent, and respond to cyber threats and intrusions.
- Review and update policies regularly, especially after system changes.

P.ISO (International Organization for Standardization)

Ans: -

The International Organization for Standardization (ISO) is an independent body that develops global standards to ensure quality, safety, security and efficiency across industries. Founded in 1947 and headquartered in Geneva, ISO creates frameworks that help organizations follow best practices in areas like manufacturing, technology, management, data security and environmental protection.

ISO isn't a government body—countries join voluntarily, and today there are over 160 member countries. ISO standards are widely respected because they create a common language for quality and security that works across borders.

Some of the most relevant ISO standards in information security and business processes include:

1. ISO 27001 – Information Security Management System (ISMS)

This is one of the most important cybersecurity standards. It provides a complete framework for managing risks related to confidentiality, integrity and availability of information. It includes:

- risk assessment
- access controls
- security policies
- incident response
- continuous monitoring

Organizations certified under ISO 27001 can demonstrate strong cyber hygiene and compliance.

2. ISO 27002 – Security Controls Guidelines

5 MARKS (CSL)

This complements ISO 27001 by giving detailed best practices for implementing technical and organizational controls such as encryption, network security, physical safeguards and policy enforcement.

3. ISO 9001 – Quality Management Systems

This standard focuses on improving process quality, consistency and customer satisfaction. It encourages organizations to document processes, measure performance and pursue continuous improvement.

4. ISO 14001 – Environmental Management Systems

This standard helps companies manage environmental responsibilities such as waste, energy use and resource efficiency.

5. ISO 22301 – Business Continuity Management

This standard ensures that organizations can continue operating during disasters, cyberattacks or system failures. It emphasizes resilience, planning and recovery strategies.

Why ISO Standards Matter

ISO standards help organizations:

- improve efficiency and consistency
- strengthen security and reduce risk
- build customer trust
- comply with regulations
- follow globally accepted best practices

In the context of information security, ISO standards (especially ISO 27001 and 27002) give companies a structured way to protect data, manage risks and prevent cyber incidents.

Q.FISMA (Federal Information Security Management Act)

Ans: -

The Federal Information Security Management Act (FISMA) is a United States law introduced in 2002 to improve the way federal agencies protect their information and IT systems. Since government departments handle sensitive national data, FISMA was created to make sure they follow a strict, consistent security framework.

At its core, FISMA requires every federal agency to develop, document and maintain a full information security program. This includes identifying risks, protecting systems, testing security controls and ensuring continuous monitoring. The law also applies to private contractors and third-party service providers who manage government data, so they must follow the same security standards.

FISMA relies heavily on the NIST (National Institute of Standards and Technology) guidelines. NIST provides detailed documents like NIST SP 800-53, which lists technical and administrative controls that agencies must implement. Examples include access controls, encryption, audit logging, incident handling and system accreditation.

Another important part of FISMA is annual security reviews. Each agency must report their security status to the Office of Management and Budget (OMB), making them accountable for weaknesses. Over time, FISMA has strengthened cybersecurity across the federal government by encouraging better documentation, risk-based decision making and continuous improvement.

In simple terms, FISMA ensures that U.S. government systems—and the partners who support them—maintain strong, measurable and well-monitored cybersecurity practices.

R. Short Note on NERC (North American Electric Reliability Corporation)

Ans: -

The North American Electric Reliability Corporation (NERC) is an independent organization responsible for keeping the North American power grid reliable and secure. Electricity grids are critical infrastructure, and even a small failure can lead to widespread blackouts. To prevent such events, NERC develops and enforces mandatory standards known as NERC Reliability Standards.

One of the most important parts of NERC's work is the NERC CIP (Critical Infrastructure Protection) standards. These cover cybersecurity protections for power plants, energy companies, control centers and other facilities involved in generating or transmitting electricity. The standards require organizations to protect their networks and equipment from cyberattacks, physical threats and operational failures.

Key NERC CIP requirements include identifying critical assets, controlling physical and electronic access, monitoring networks, logging activities,

maintaining incident response plans and performing regular audits and training. Non-compliance can lead to heavy fines because the consequences of failure can be extremely serious.

NERC's goal is to ensure that the electric grid remains stable, resilient and secure even when faced with cyber threats, natural disasters or system failures. As cyberattacks on energy infrastructure increase globally, NERC plays a crucial role in safeguarding one of the most essential services in modern life.

S. PCI (Payment Card Industry – PCI DSS)

Ans: -

The Payment Card Industry Data Security Standard (PCI DSS) is a global security standard created to protect cardholder data during payment processing. It applies to any business—big or small—that stores, processes or transmits credit card information from brands like Visa, MasterCard, American Express or Discover.

PCI DSS was introduced because credit card fraud and data breaches were becoming increasingly common. The standard lays down a set of detailed security requirements that organizations must follow to keep card data safe. These include building secure networks, encrypting cardholder information, protecting systems from malware, restricting access to sensitive data and regularly testing security controls.

Some key PCI DSS principles include:

- installing and maintaining firewalls
- encrypting data during transmission
- using strong access controls
- monitoring and logging all access to card data
- vulnerability scanning and penetration testing
- maintaining an information security policy

PCI also classifies organizations into different compliance levels based on how many transactions they handle each year. Larger merchants must undergo external audits, while smaller ones may only need self-assessment questionnaires.

The overall goal of PCI is to reduce the risk of card theft, fraud and hacking by making sure every organization in the payment ecosystem follows strong, standardized security practices.